

COMP4337 - Lab04

Prepared by Saron (z5419561) and Muhammed (z5361979)

Part A

1. The domain being queried is w0rld.secilmisler.com and has the corresponding IP 84.244.1.30.

The name servers queried for this response are:

- NS ns2.tr-shell.net
 - A 89.149.196.215
 - NS ns1.tr-shell.net
 - A 89.149.196.216
2.
 - a. 84.244.1.30 - russia
 - b. 89.149.196.215 - Netherlands
 - c. 89.149.196.216 - Netherlands
 3. Port 5050;
 4. Port 5050 is commonly used by the 'eggdrop' bot, an early internet bot. The port is also used by the following services:
 - Yahoo Messenger
 - R0xr4t Symantec-2002-082915-1621-99, a.k.a. RoxRat backdoor, BD R0xr4t 1.0.
 - EOSScoreScada.exe in C3-ilex EOSScada
 - BT Communicator uses ports 5050-5070 (TCP/UDP).

The TCP stream shows that the bot (infected computer) has connected to a Command and Control server, which is a server used by an attacker to communicate with compromised hosts. Via the CandC server, the bot is talking to the attacker who appears as commander@admin.local on the 'reptile' channel. The attacker issues various commands to the bot including '.VERSION' and '.id'.

5. DNS request to www.kinchan.net
6. The cgi file that the bot is attempting to retrieve is /cgi-bin/proxy.cgi.
7. An everyday Internet user can use search engines with safe browsing mode like Google, antivirus software with web monitoring like Norton as well as other websites that scan URLs for common threats and malware to check if a URL is safe to visit.

Win32/Spybotorm is a worm that targets windows computers, by exploiting network shares with weak admin passwords. It is used to gain access to admin, system and shared folders and is also able to communicate with a remote attacker through FTP.

Other common types of malware include:

- Trojans, which refer to programs that appear to be harmless but are in fact malicious
- Ransom, which refers to malware that encrypts a computer's storage and makes it unusable until the victim pays a ransom to decrypt it
- Keyloggers, which are programs that record the keystrokes entered by a user and are commonly used to steal sensitive information such as passwords and bank details

8. To prevent attacks such as malware, a firewall should be used and configured to drop packets with suspicious IPs or those known to be harmful. Firewalls are effective because they provide 24/7 protection against attacks and can also be used to log suspicious activity for review by a security manager. Additionally, an IDS (Intrusion Detection System) can also be used to detect malicious activity while SIEMs (Security information and event management) are capable of processing data to alert admins to potentially harmful events or activity

Part B

1.
 - a.
 - i. Pkt # = 12
 - ii. Src = client (port 58778)
 - iii. # SSL records = 1
 - iv. SSL records = Client Hello
 - b.
 - i. Pkt # = 14
 - ii. Src = server (port 25)
 - iii. # SSL records = 4
 - iv. SSL records = Server Hello, PKC, Server Key Exchange, Server Hello Done
 - c.
 - i. Pkt # = 16
 - ii. Src = client
 - iii. # SSL records = 3
 - iv. SSL records = Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
 - d.
 - i. Pkt # = 18
 - ii. Src = server
 - iii. # SSL records = 1
 - iv. SSL records = Change Cipher Spec
 - e.
 - i. Pkt # = 20
 - ii. Src = server
 - iii. # SSL records = 1
 - iv. SSL records = Encrypted Handshake Message
 - f.
 - i. Pkt # = 30
 - ii. Src = client
 - iii. # SSL records = 1
 - iv. SSL records = Encrypted Handshake Message
- 2.

- a. The Nonce C is
eb077f45cf6cb0145390c4f1c86f3b7dc3e9868c00fdcf791e414acc.
- b. The client supports 97 cipher suites, excluding the empty renegotiation option.
The first cipher suite is "Cipher Suite:
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384".
 - i. Key exchange = Elliptic Curve Diffie Hellman Exchange (ECDHE)
 - ii. Digital signature = RSA
 - iii. Encryption algorithm = AES-256 GCM mode
 - iv. Hashing = SHA384
- c. The client supports 4 different HMAC algorithms (SHA-1, SHA384, SHA256 and MD5). For the last suite, the signature algorithm is RSA and the hash is MD5.

3.

- a. The server chose the cipher suite: "Cipher Suite:
TLS_DHE_RSA_WITH_AES_256_CBC_SHA256". The suite contains Diffie-hellman (key exchange), RSA (signature), aes-256 cbc (encryption) and sha256 (hashing).
- b. ServerHello includes a nonce of 28 bytes length. The purpose of client and server nonces is to prevent relay attacks by a PiTM by using a once-in-a-lifetime value in the generation of session keys.
- c. ServerHello includes a 32-byte session ID that is used to resume a connection with the same client. Both server and client map the other's IP and port number to the session ID and the server also stores the state of the handshake in the mapping. In the future, if a client wants to reconnect, they send the same session ID to the server and the server is able to restore the session by querying its cache, avoiding the need for a full handshake.
- d. The ServerHello packet contains a truncated version of the certificate, encrypted using SHA256 with RSA. The certificate is sent in a single ethernet frame and belongs to mail.example.com, which is located in the Netherlands (NL).

e.

- i. $g =$
2174464614324321605702022855115620875270394288720730886866444527
5548674736620508732925764357515199547303283870847514971207187185
91291743488989946216334211646350465118756727157777337013657445667
1482796328194698430314464307239426297609039182878000113673163760
38157562992859303856353623495856321338549544554191116841474125049
4418615704883548296728080545795859843320405072472266753448906714
6056373086424684228985586308124876361888196771301349638330409484
1124390802820018345440306786653974729139473297014240154418713762
4428138444276721310399530477238861596789940953323090393313600101
710523922727140772179016720953265564666 (decimal)

Ac4032ef4f2d9ae39df30b5c8ffdac506cdebe7b89998caf74866a08cfe4ffe3a6824
a4e10b9a6f0dd921f01a70c4afaab739d7700c29f52c57db17c620a8652be5e9001
a8d66ad7c17669101999024af4d027275ac1348bb8a762d0521bc98ae24715042
2ea1ed409939d54da7460cdb5f6c6b250717cbef180eb34118e98d119529a45d6f

834566e3025e316a330efbb77a86f0c1ab15b051ae3d428c8f8acb70a8137150b8
eeb10e183edd19963ddd9e263e4770589ef6aa21e7f5f2ff381b539cce3409d13cd
566afbb48d6c019181e1bcfe94b30269edfe72fe9b6aa4bd7b5a0f1c71cfff4c19c41
8e1f6ec017981bc087f2a7065b384b890d3191f2bfa (hex)

ii. P =

2184735958988820847550672491716226506357140198532537036763136178
11140296530259568151576053281904111410441606898157413193811965329
7987150003897986230915873825094511855496162682415230753660587261
6502884288878062467052777605227846709781850614792748458838951342
2048126018381129378053717826003801060205228844064528238188244556
83982042882928183431194593189171431066371138510252979648513553078
7625845961474274568372896230088793648294777051836361493041209989
48654278133874026711188494311770883514889363351380064520413459602
69614135394940797181007184835412786872593405781105228551172607095
1954828625761984797831079801857828431 (decimal)

Ad107e1e9123a9d0d660faa79559c51fa20d64e5683b9fd1b54b1597b61d0a75e6
fa141df95a56dbaf9a3c407ba1df15eb3d688a309c180e1de6b85a1274a0a66d3f8
152ad6ac2129037c9edefda4df8d91e8fef55b7394b7ad5b7d0b6c12207c9f98d11
ed34dbf6c6ba0b2c8bbc27be6a00e0a0b9c49708b3bf8a317091883681286130bc
8985db1602e714415d9330278273c7de31efdc7310f7121fd5a07415987d9adc0a
486dcdf93acc44328387315d75e198c641a480cd86a1b9e587e8be60e69cc928b
2b9c52172e413042e9b23f10b0e16e79763c9b53dcf4ba80a29e3fb73c16b8e75b
97ef363e2ffa31f71cf9de5384e71b81c0ac4dffe0c10e64f

iii. Public key =

375ac727e893eaa252cd21368d644f594329f5bf8d920d7958c79c82337f581ba90
d4326a3d042d08bb3eb896f2f124e77d6af14aeb74de01a48d59f7e109a373d7ff5
31050ea5956f89223b84a6e0de797d434e8865e73a4e26d25f126ba2c4e80b229
aa34f8ee38774fa429f008f2a8c0dec7c064b83ec2043848b8c831ab3f52725ff729
9728a7bfeff76641294cf25120636d4102bb5e477d69371d6354792bcf04226ee05
bc3225bb74c843cccf2f44600956cf5480d81e38b14b428ed812d26107a0a3a85
414aec9fd375ab9639819f83cc6fc207ddd0b791a17c9194efec4bed49316fcd6c27
bc4227c3f0ba7aa408050955f4b0473d135b57acd753

4.

a. Client public key =

589c62500568139e8d5e3419df3d4918c1e25a5556608ebabd41dcbd9784d9d93813e92
d2935235517659e4c8a5caa53aea932d825a58a70c3a89f3b189cfe65865abd172af0906
4e5d1956a1270f0a8e0e9baa9d6d36e12d2944dfc0af16c65fba4f8213f973ecc594ebc8d3
baa8766085efeea73a290e08a233c61a4ec009871894edc2a76bf46e97d5af153c61ef01e
3958e7e3c829417fc96b9c360ae52bd04dfd965bbd53513f2effd6b2821f26d6a5c350ddf8
a87c422a26775940aa416dfa029ec5a4fbcd08e69d91f7c2f328b145fadd1269ecfe8d6f19
ef14c1210eb28114dd8b9530a4bdb5c6a8b7c941ac7cf4337f0af36e4299fad6b8810e1fcd

The packet does not contain the pre-master key as this is randomly generated by the client and later sent in an encrypted format to the server.

- b. The Change Cipher Spec record is used by the client to inform the server that it generated the session keys and will start to encrypt its packets with them. The record is 2 bytes (value is 1 byte).
- c. The client encrypts the pre-master secret using the server's public key (from its public key certificate) and sends it to the server as part of the Encrypted handshake record.

5. The server sends its own Change Cipher Spec record to the client to indicate that it has generated the session keys from the pre-master secret and will now encrypt all future packets. This is similar to the client's change cipher spec record.

The server also sends an Encrypted Handshake Message packet which contains the verification data, instead of the pre-master secret from the client. This consists of the master key as well as the complete handshake between client and server.

6. The application data is encrypted using the four session keys independently generated by the client and server using the pre-master key. These session keys consist of an encryption key for packet payloads from client to server as well as server to client and MAC keys for packets from client to server and server to client. The packets are encrypted using AES-256 in CBC mode and the MACs are encrypted using RSA, as determined during the handshaking.

SMTP (Simple Mail Transfer Protocol) is using TLS.

The client uses different encryption keys to the server, but since the server has already generated the key used by the client, it can easily decrypt packets sent by the client, and vice-versa.

7.

pkt 12

C → S: Client Hello

Pkt 14

C ← S: Server Hello

C ← S: Server Public Certificate

C ← S: Server Key Exchange

C ← S: Server Hello Done

Pkt 16

C → S: Client Key Exchange

C → S: Change Cipher Spec

C → S: PreMaster Secret

Pkt 18

C ← S: Change Cipher Spec

Pkt 20

$C \leftarrow S$: Encrypted Verification Data